

Настройка доверенных SSL/TLS сертификатов для защиты RDP подключений

 vsydorenko.gitbook.io/sysadminisnotes/nastroika-doverennykh-ssl-tls-sertifikatov-dlya-zashity-rdp-podklyuchenii

April 12, 2022

 SysadminisNotes

Настройка доверенных SSL/TLS сертификатов для защиты RDP подключ...

For the complete documentation index, see [llms.txt](#). This page is also available as [Markdown](#).

В этой статье мы покажем, как использовать доверенные SSL/TLS сертификаты для защиты RDP подключений к компьютерам и серверам Windows в домене Active Directory. Эти сертификаты мы будем использовать вместо самоподписанных RDP сертификатов (у пользователей появляется предупреждение о невозможности проверки подлинности при подключению к RDP хосту с таким сертификатом). В этом примере мы настроим специальный шаблон для выпуска RDP сертификатов в Certificate Authority и настроим групповую политику для автоматического выпуска и привязки SSL/TLS сертификата к службе Remote Desktop Services.

Содержание:

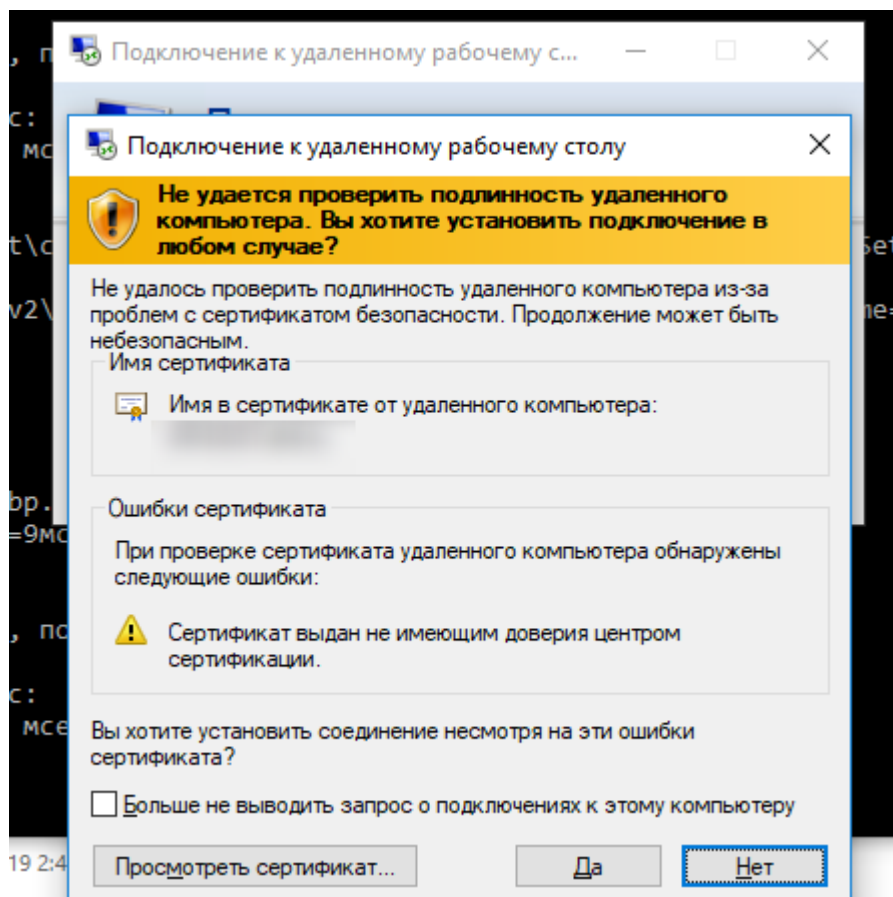
Предупреждение о самоподписанном сертификате RDP

По умолчанию в Windows для защиты RDP сессии генерируется [самоподписанный сертификат](#). В результате при первом подключении к RDP/RDS серверу через клиента mstsc.exe, у пользователя появляется предупреждение:

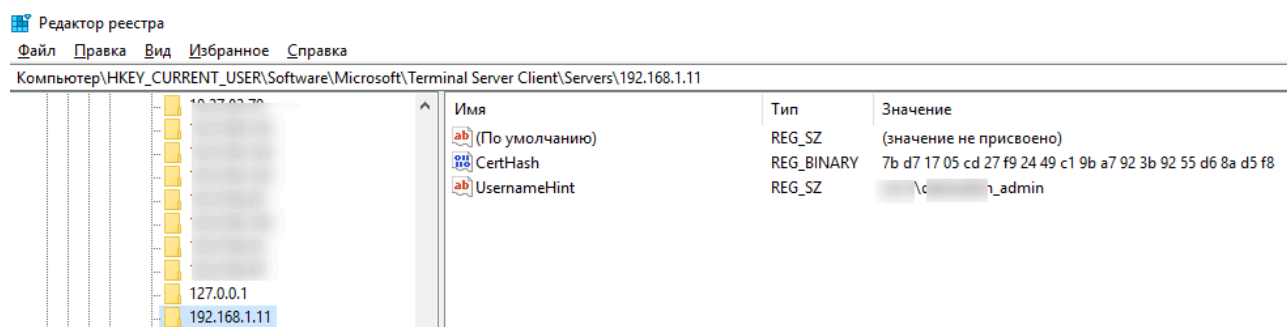
Не удалось проверить подлинность удаленного компьютер из-за проблем с сертификатом безопасности.

Ошибка сертификата: сертификат выдан не имеющим доверия центром сертификации.

Чтобы продолжить установление RDP подключения пользователь должен нажать кнопку Да. Чтобы RDP предупреждение не появлялось каждый раз, можно включить опцию «Больше не выводить запрос о подключениях к этому компьютеру».



При этом отпечаток RDP сертификата сохраняется на клиенте в параметре **CertHash** в ветке реестра [с историей RDP подключений](#) (HKEY_CURRENT_USER\Software\Microsoft\Terminal Server Client\Servers\). Если вы скрыли уведомление о невозможности проверить подлинность RDP сервера, чтобы сбросить настройки, удалите ключ с отпечатком сертификата из реестра.



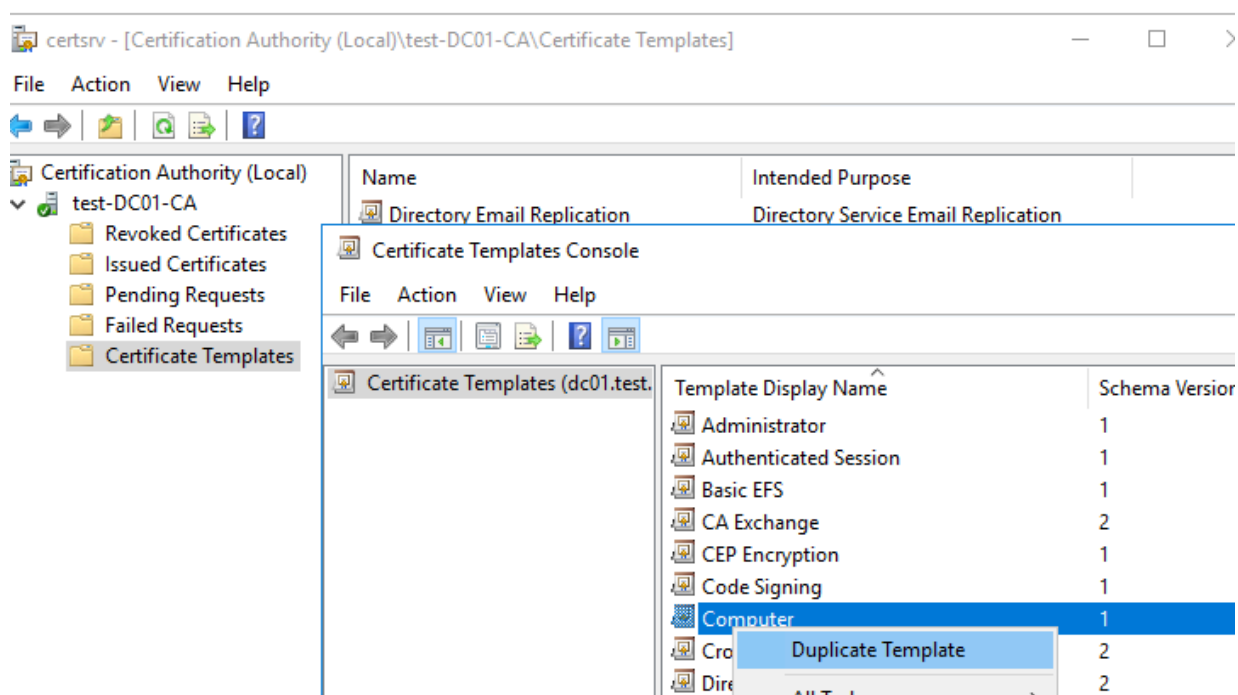
Несмотря на то, что для подключения используется самоподписанный сертификат, ваше RDP подключение защищено, а трафик зашифрован.

Создаем шаблон RDP сертификата в центре сертификации (CA)

Попробуем использовать для защиты RDP подключений доверенный SSL/TLS сертификат, выданный корпоративным центром сертификации. С помощью такого сертификата пользователь может выполнить проверку подлинности RDP сервера при подключении. Предположим, что у вас в домене уже развернут корпоративной центр сертификации (Microsoft Certificate Authority), в этом случае вы можете настроить автоматическую выдачу и подключение сертификатов всем компьютерам и серверам Windows в домене.

И на вашем CA нужно создать новый тип шаблона сертификата для RDP/RDS серверов.

1. Запустите консоль Certificate Authority и перейдите в секцию Certificate Templates;
2. Сделайте копию шаблона сертификата Computer (Certificate Templates -> Manage -> Computer -> Duplicate);



3. На вкладке **General** укажите имя нового шаблона сертификата – **RDPTemplate**. Убедитесь, что значение поля **Template Name** полностью совпадает с **Template display name**;

The screenshot shows the 'Properties of New Template' dialog box with the 'General' tab selected. The 'Template display name' and 'Template name' fields both contain 'RDPTemplate'. The 'Validity period' is set to '1 years' and the 'Renewal period' is set to '6 weeks'. The checkbox 'Publish certificate in Active Directory' is unchecked, and the sub-checkbox 'Do not automatically reenroll if a duplicate certificate exists in Active Directory' is also unchecked. The 'Cancel' button is highlighted with a blue border.

Superseded Templates		Extensions		Security	
Subject Name		Server		Issuance Requirements	
Compatibility	General	Request Handling	Cryptography	Key Attestation	

Template display name:
RDPTemplate

Template name:
RDPTemplate

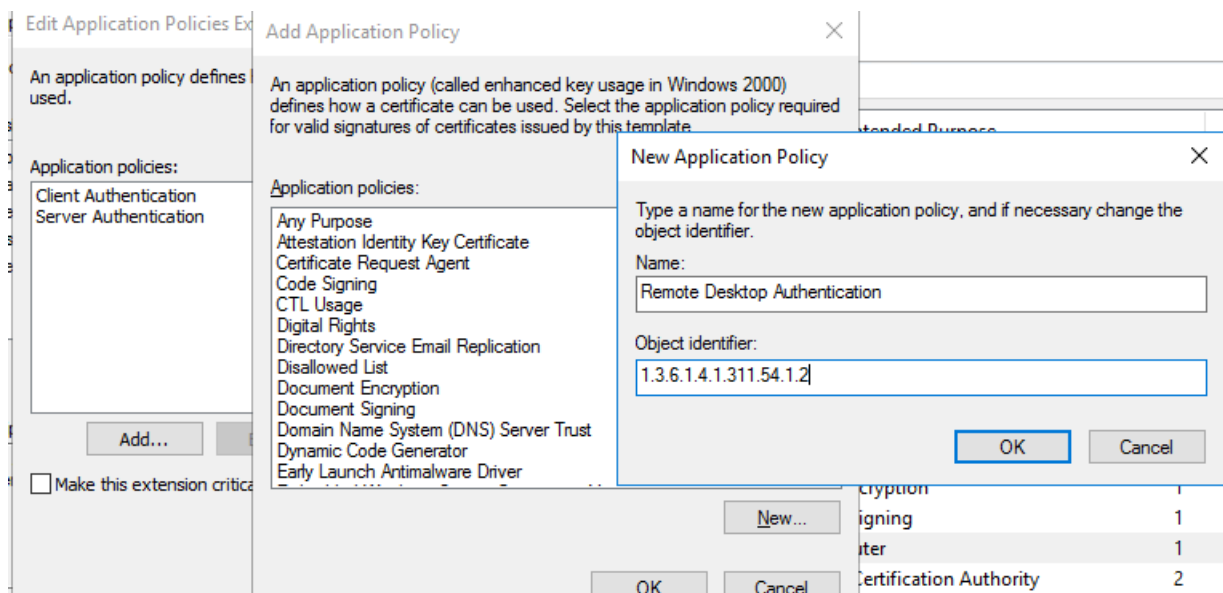
Validity period: 1 years
Renewal period: 6 weeks

☐ Publish certificate in Active Directory
☐ Do not automatically reenroll if a duplicate certificate exists in Active Directory

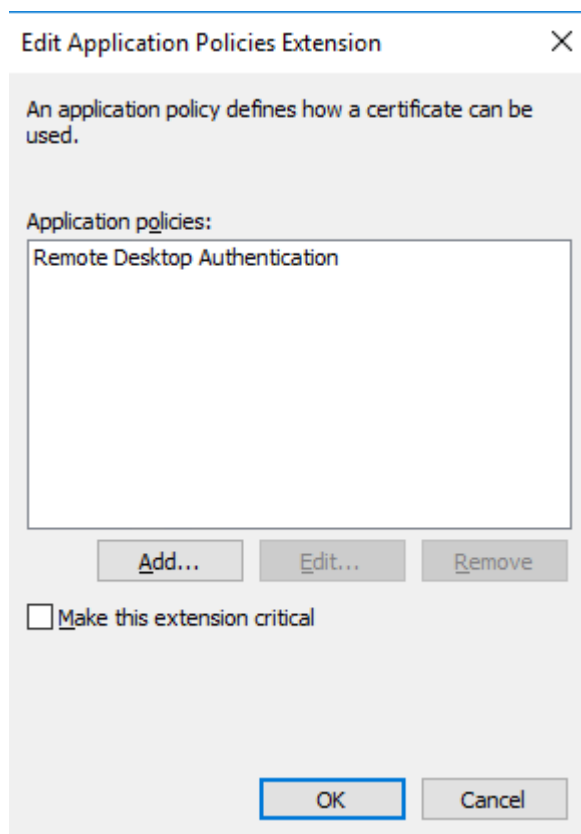
OK Cancel Apply Help

4. На вкладке **Compatibility** укажите минимальную версию клиентов в вашем домене (например, Windows Server 2008 R2 для CA и Windows 7 для клиентов). Тем самым будут использоваться более стойкие алгоритмы шифрования;

5. Теперь на вкладке **Extensions** в политике приложений (Application policy) нужно ограничить область использования такого сертификата только для **Remote Desktop Authentication** (укажите следующий object identifier — **1.3.6.1.4.1.311.54.1.2**). Нажмите Add -> New, создайте новую политику и выберите ее;



6. В настройках шаблона сертификата (Application Policies Extension) удалите все политики кроме **Remote Desktop Authentication**;



7. Чтобы использовать данный шаблон RDP сертификатов на контролерах домена, откройте вкладку **Security**, добавьте группу **Domain Controllers** и включите для нее опцию **Enroll** и **Autoenroll**;

Properties of New Template ✕

Subject Name		Server	Issuance Requirements	
Compatibility	General	Request Handling	Cryptography	Key Attestation
Superseded Templates		Extensions		Security

Group or user names:

- Authenticated Users
- Administrator
- Domain Admins (TEST\Domain Admins)
- Domain Computers (TEST\Domain Computers)
- Domain Controllers (TEST\Domain Controllers)
- Enterprise Admins (TEST\Enterprise Admins)

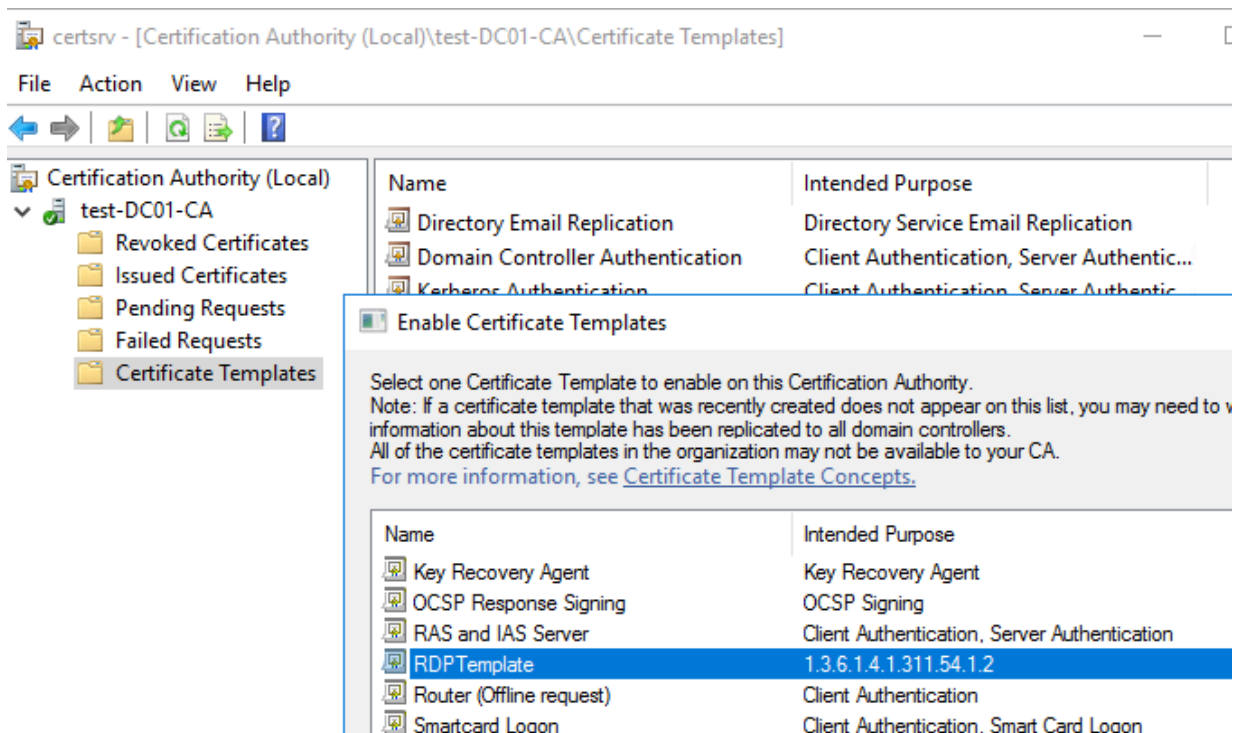
Add... Remove

Permissions for Domain Controllers	Allow	Deny
Full Control	☐	☐
Read	☒	☐
Write	☐	☐
Enroll	☒	☐
Autoenroll	☐	☐

For special permissions or advanced settings, click Advanced. Advanced

8. Сохраните шаблон сертификата;

9. Теперь в оснастке Certificate Authority, щёлкните по папке Certificate Templates, выберите **New -> Certificate Template to Issue ->** выберите созданный шаблон **RDPTemplate**.



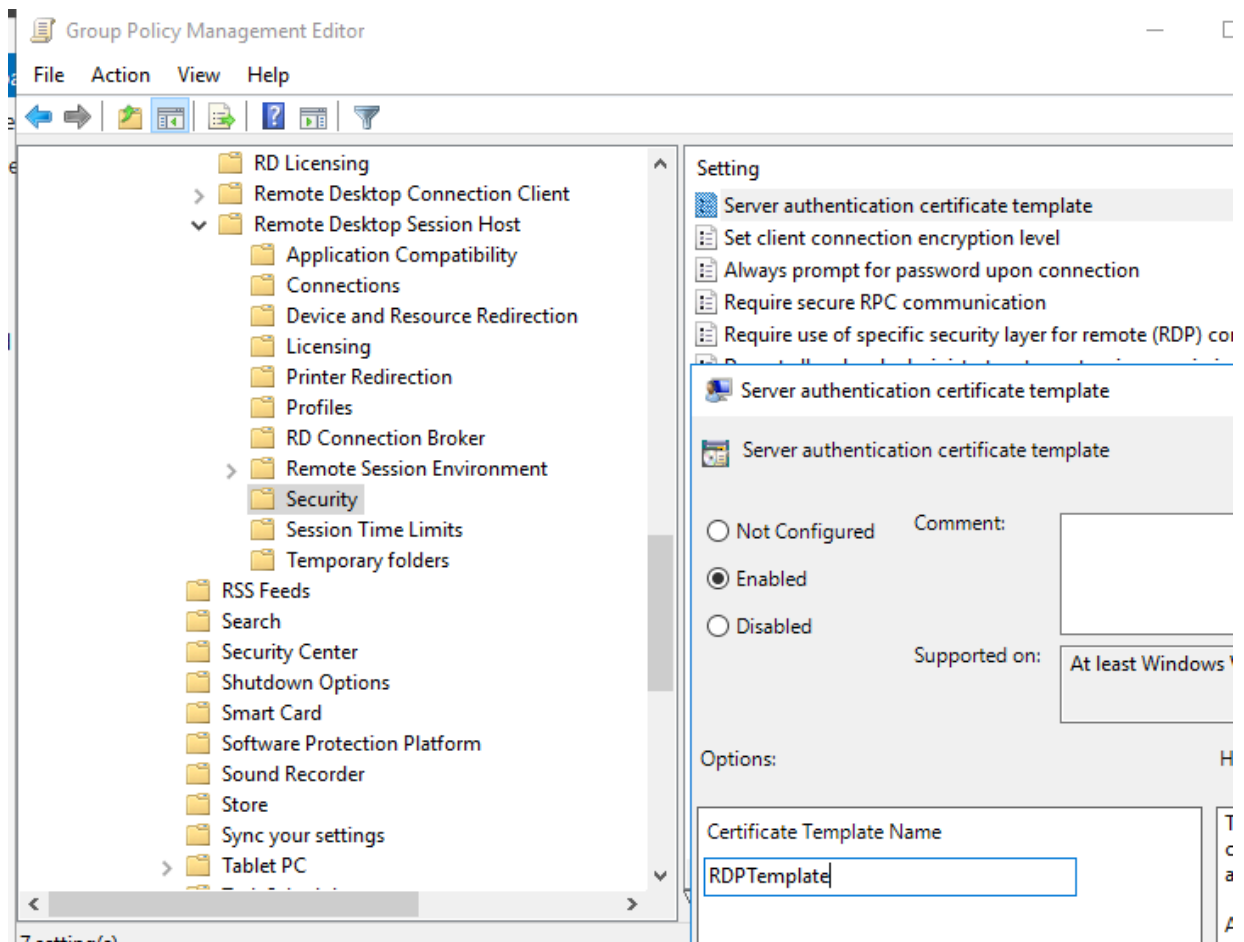
Настройка групповой политики для выдачи RDP сертификатов

Теперь нужно настроить доменную политику, которая будет автоматически назначать RDP сертификат компьютерам/серверам согласно настроенного шаблона.

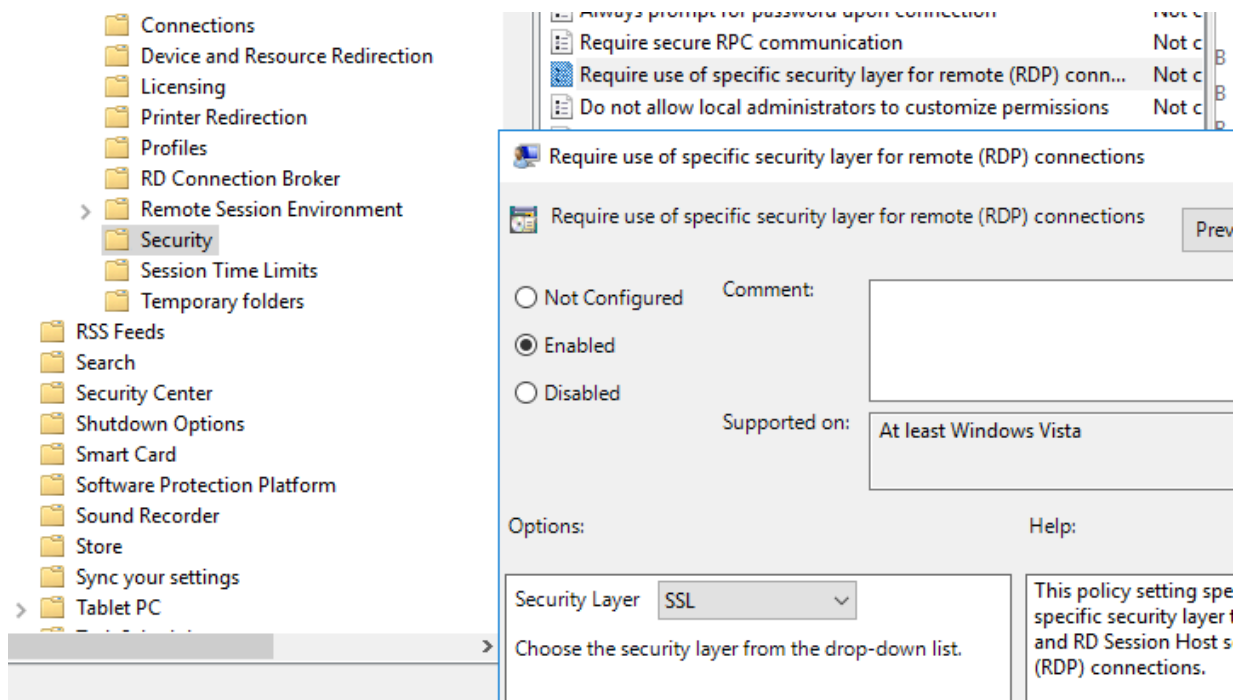
Предполагается, что все компьютеры домена доверяют корпоративному центру сертификации, т.е. [корневой сертификат через GPO](#) добавлен в доверенные корневые центры сертификации.

1. Откройте консоль управления доменными групповыми политиками `gpmc.msc`, создайте новый объект GPO и назначьте его на OU с RDP/RDS серверами или компьютерами, для которых нужно автоматически выдавать TLS сертификаты для защиты RDP подключения;

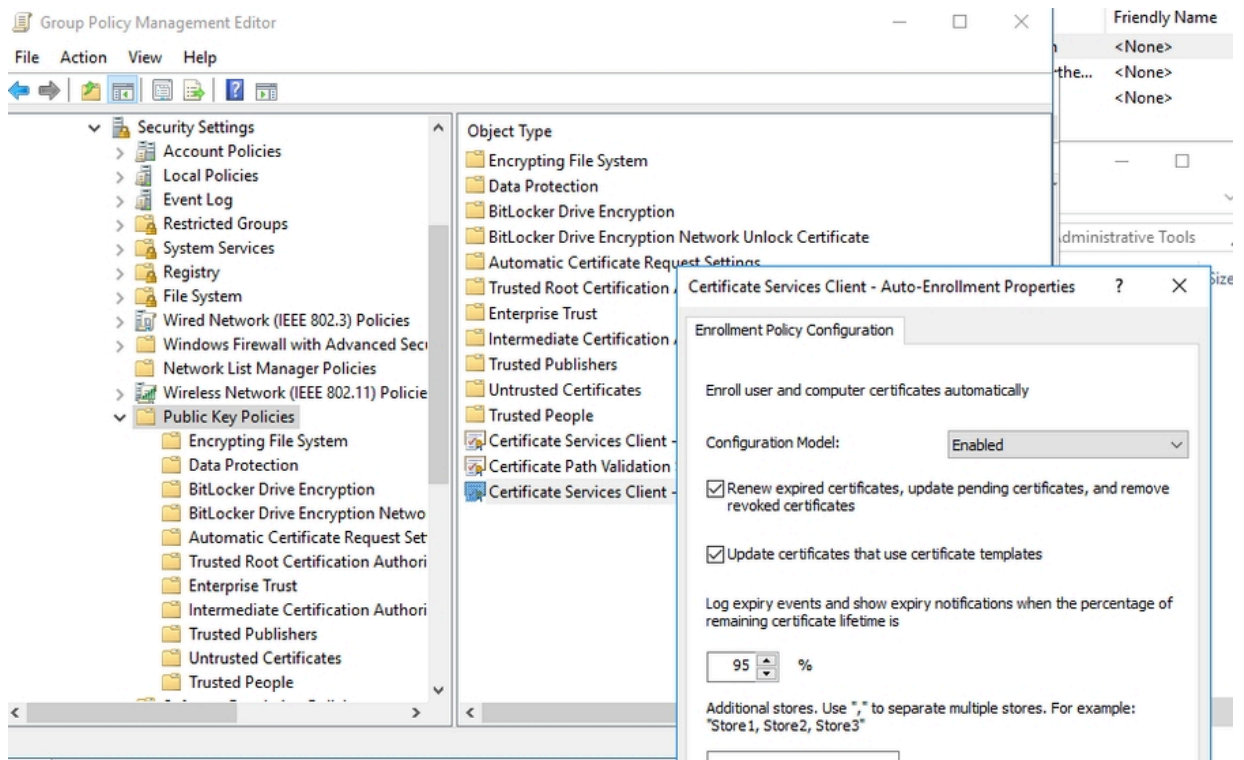
2. Перейдите в раздел GPO: Computer Configuration -> Policies -> Administrative Templates -> Windows Components -> Remote Desktop Services -> Remote Desktop Session Host -> Security. Включите политику **Server Authentication Certificate Template**. Укажите имя шаблона СА, который вы создали ранее (**RDPTemplate**);



3. Затем в этом же разделе GPO включите политику **Require use of specific security layer for remote (RDP) connections** и установите для нее значение **SSL**;



4. Для автоматического продления RDP сертификата, перейдите в раздел GPO Computer configuration -> Windows settings -> Security Settings -> Public Key Policies и включите политику **Certificate Services Client – Auto-Enrollment Properties**. Выберите опции “Renew expired certificates, update pending certificates and remove revoked certificates” и “Update certificates that use certificate templates”;



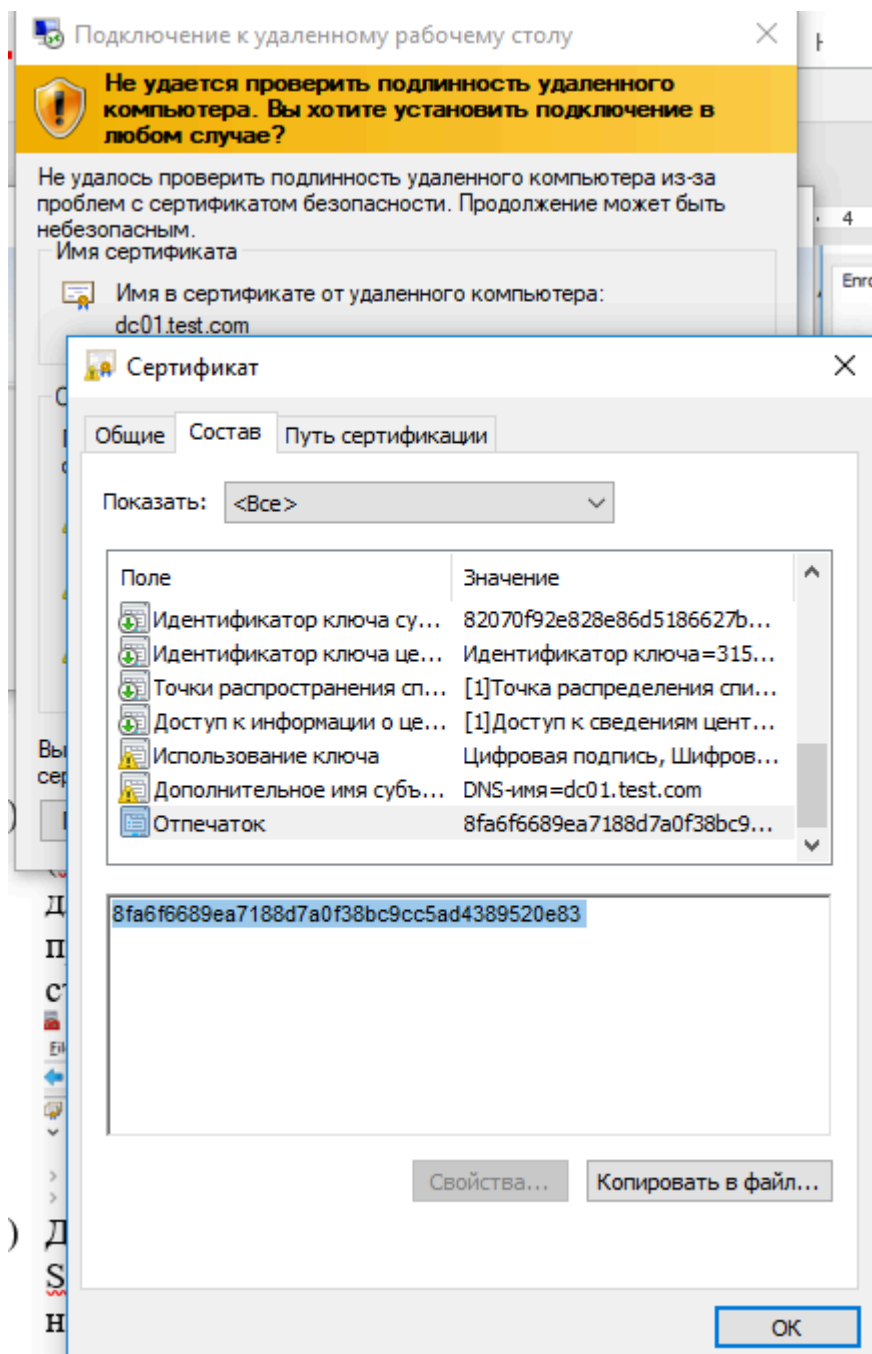
5. Если вы хотите, чтобы клиенты всегда проверяли сертификат RDP сервера, вам нужно настроить политику **Configure Authentication for Client = Warn me if authentication fails** (секция GPO Computer Configuration -> Policies -> Administrative Templates -> Windows Components -> Remote Desktop Settings -> Remote Desktop Connection Client);
6. Осталось [обновить политики](#) на клиенте, запустить консоль сертификатов компьютера (Certlm.msc), и проверить, что в разделе Personal -> Certificates появился сертификат для Remote Desktop Authentication, выданный вашим СА. Если политики не применились, для диагностики GPO воспользуйтесь утилитой [gpresult](#) и [этой](#) статьей.

Для применения нового RDP сертификата, перезапустите службу Remote Desktop Services:

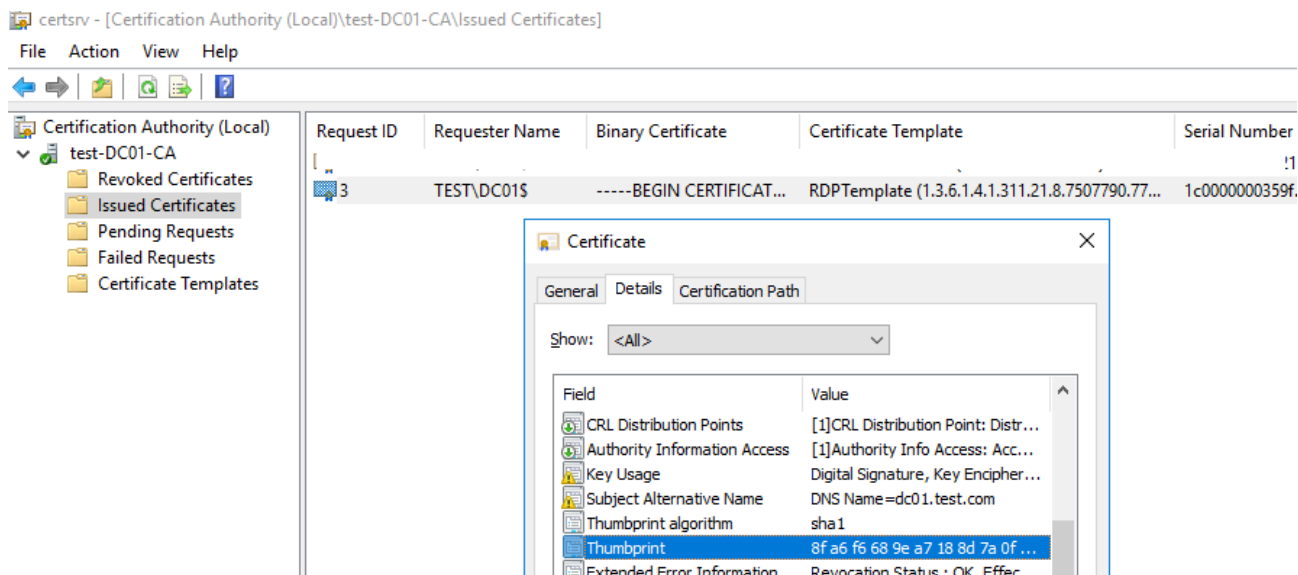
```
Get-Service TermService -ComputerName msk-dc01| Restart-Service -force  
-verbose
```

Теперь при RDP подключении к серверу перестанет появляться запрос на доверие сертификату (чтобы появился запрос о доверии сертификату, подключитесь к серверу по IP адресу вместо FQDN имени сервера, для которого выпущен сертификат). Нажмите кнопку "Посмотреть сертификат", перейдите на вкладку

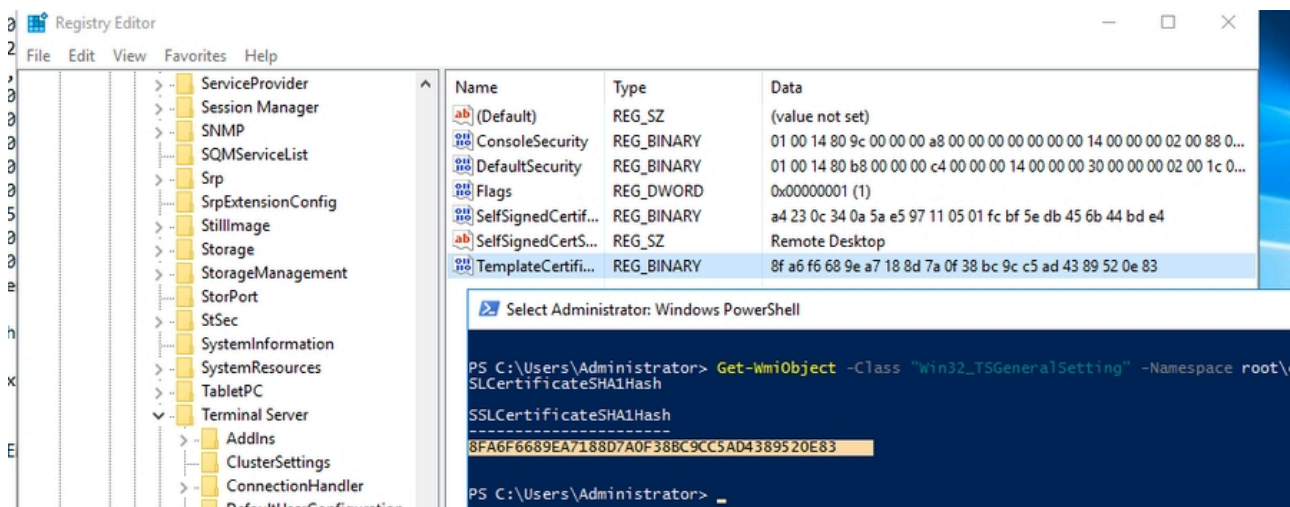
“Состав”, скопируйте значение поля “Отпечаток сертификата”.



Также можете в консоли Certification Authority в секции **Issued Certificates** проверить, что по шаблону RDPTemplate был выдан сертификат определённому Windows компьютеру/серверу. Также проверьте значение Thumbprint сертификата:



Теперь сравните полученные данные с отпечатком сертификата, который используется службой Remote Desktop Service. Вы можете посмотреть значение отпечатка сертификата службы RDS в реестре (ветка **HKLM:\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations**, параметр **TemplateCertificate**) или командой PowerShell: `Get-WmiObject -Class "Win32_TSGeneralSetting" -Namespace root\cimv2\terminalservices | select SSLCertificateSHA1Hash`



Теперь, при подключении к удаленному столу любого сервера или компьютера, на который действует эта политика, вы не увидите предупреждения о недоверенном RDP сертификате.

Подписываем RDP файл и добавляем отпечаток доверенного RDP сертификата

Если у вас отсутствует CA, но вы хотите, чтобы при подключении к RDP/RDS серверу у пользователей не появлялось предупреждения, вы можете добавить сертификат в доверенные на компьютерах пользователей.

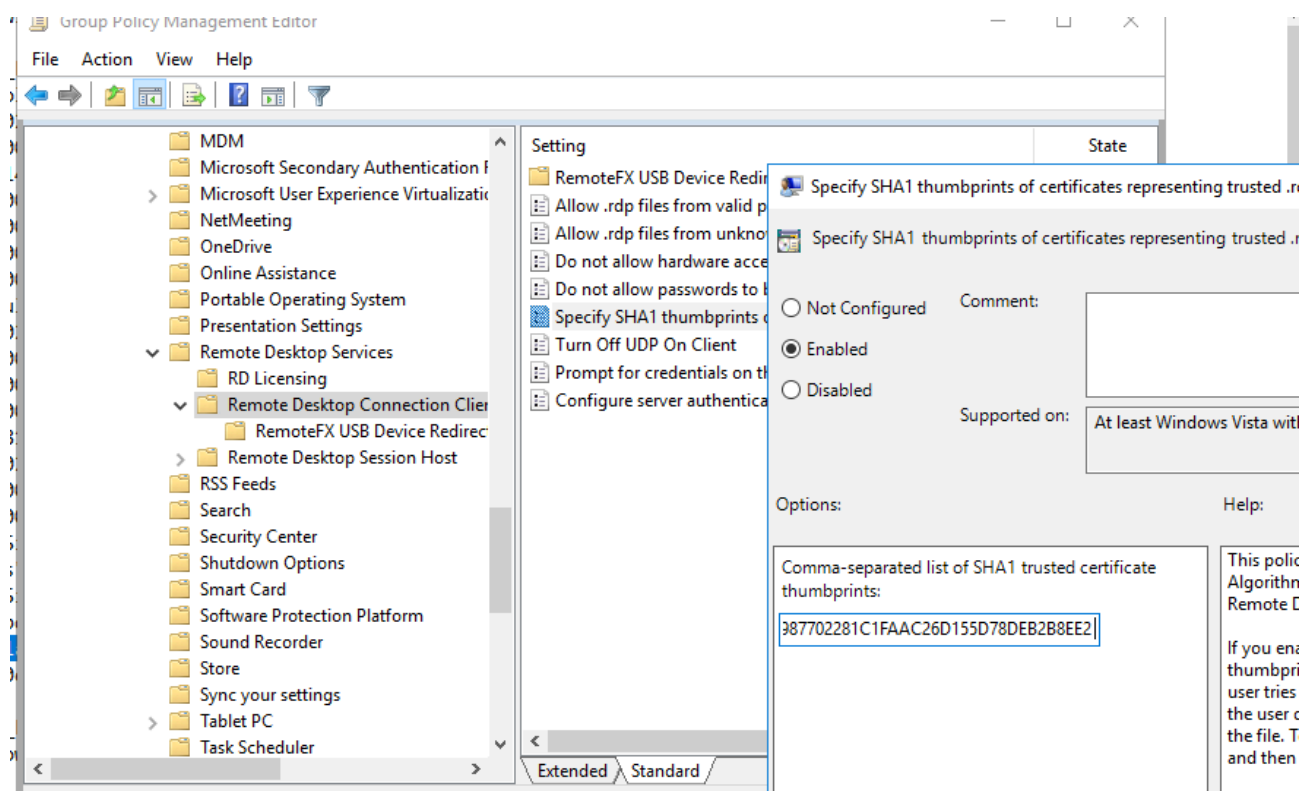
Как описано выше получите значение отпечатка (Thumbprint) RDP сертификата:

```
Get-WmiObject -Class "Win32_TSGeneralSetting" -Namespace  
root\cimv2\terminalservices|select|select SSLCertificateSHA1Hash
```

Используйте этот отпечаток для подписывания .RDP файла с помощью **RDPSign.exe**:

```
rdpsign.exe /sha256 65A27B2987702281C1FAAC26D155D78DEB2B8EE2  
"C:\Users\root\Desktop\rdp.rdp"
```

Теперь через GPO добавим этот отпечаток сертификата в доверенные у пользователей. Укажите отпечатки (через точку с запятой) в политике **Specify SHA1 thumbprints of certificates representing trusted .rdp publishers** (Указать отпечатки SHA1 сертификатов, представляющих доверенных издателей RDP) в секции Computer Configuration -> Policies -> Administrative Templates -> Windows Components -> Remote Desktop Settings -> Remote Desktop Connection Client.



Чтобы работал прозрачный RDP вход без ввода пароля ([RDP Single Sign On](#)), нужно настроить политику Allow delegation defaults credential и указать в ней имена RDP/RDS серверов (см. [статью](#)).

Останне оновлення